

# Architecture de Chiffrement HTTPS End-to-End

Étude comparative des options de PKI interne (AD CS vs PKI Publique) & Déploiement Automatisé

**Domaine principal :**  
optimedit.eu

**Reverse Proxy :** rp.optimedit.eu

**Serveurs Web :** srv-web01,  
srv-web02

**Sous-domaines (Cas 1) :**  
direction, rh, compta

**Sous-dossiers (Cas 2) :** /sites/direction, /  
sites/rh, /sites/compta

**Sécurité :** Chiffrement TLS de  
bout en bout

## 1. Principes de la Chaîne de Chiffrement End-to-End

Dans une architecture de chiffrement de bout en bout (End-to-End), le flux est chiffré depuis l'utilisateur jusqu'au serveur web final. Le **Reverse Proxy (RP)** déchiffre la requête entrante du client (flux externe) puis ré-chiffre la communication vers `srv-web01` ou `srv-web02` (flux interne).

### Composants de Certificats Communs aux Deux Cas :

- **Certificat Public Front-End (RP) :** Un certificat émis par une PKI publique (ex: Let's Encrypt, DigiCert) est installé sur `rp.optimedit.eu`. Il inclut dans son SAN le FQDN du RP ainsi que les sous-domaines (`direction.optimedit.eu`, `rh.optimedit.eu`, `compta.optimedit.eu`) ou le domaine unifié (`optimedit.eu`, `*.optimedit.eu`).
- **Certificats Back-End (Serveurs Web) :** Chaque serveur web (`srv-web01` et `srv-web02`) possède son propre certificat SSL/TLS incluant les SANs requis pour répondre aux requêtes transmises par le RP.

## 2. Comparatif des Deux Architectures pour la Partie HTTPS Interne

| CRITÈRE D'ANALYSE            | OPTION A : PKI PUBLIQUE INTERNE                                                                                                                                                                                                                                     | OPTION B : PKI ENTREPRISE INTERNE                                                                                                                                                                                                                                   |
|------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                              | CERTIFY MANAGEMENT HUB / POWERSHELL / CCS                                                                                                                                                                                                                           | ACTIVE DIRECTORY CS / POWERSHELL / ANSIBLE                                                                                                                                                                                                                          |
| Description Générale         | Utilisation d'une PKI publique (ACME / Let's Encrypt / ZeroSSL) directement sur les serveurs web internes via un orchestrateur centralisé (Certify Management Hub) ou des scripts PowerShell (ACME-PS) / IIS Centralized Certificate Store (CCS).                   | Utilisation de la PKI privée d'entreprise Microsoft AD CS (Active Directory Certificate Services). Les certificats sont générés en interne et déployés via GPO, scripts PowerShell (Tâches planifiées) ou Ansible (Cron / Playbooks).                               |
| Sécurité & Confiance (Trust) | <ul style="list-style-type: none"><li>✓ <b>Confiance native</b> : Reconnue par défaut par n'importe quel système.</li><li>✗ <b>Exposition requise</b> : Nécessite un accès Internet sortant (ou validation DNS-01 via API DNS) sur les serveurs internes.</li></ul> | <ul style="list-style-type: none"><li>✓ <b>Isolation totale</b> : Aucune dépendance ni ouverture vers Internet requis.</li><li>✗ <b>Magasin de confiance</b> : L'autorité racine (CA Root AD CS) doit être déployée sur le Reverse Proxy et les serveurs.</li></ul> |
| Automate & Déploiement       | <ul style="list-style-type: none"><li>• <b>Certify Management Hub / ACME-PS</b> : Tâches automatisées de renouvellement.</li><li>• <b>IIS CCS</b> : Partage centralisé des certificats PFX sur un partage réseau.</li></ul>                                         | <ul style="list-style-type: none"><li>• <b>Windows</b> : Script PowerShell + Tâche planifiée pour solliciter AD CS via l'API Web/Enrollment.</li><li>• <b>Linux / Ansible</b> : Rôle Ansible / Cron déclenchant l'auto-enrollment ou la requête à la PKI.</li></ul> |
| Gestion de la Validité       | ✗ <b>Durée courte (90 jours)</b> : Impose une automatisation ultra-fiable et constante sous peine de rupture d'accès.                                                                                                                                               | ✓ <b>Durée modulable (1 à 2 ans+)</b> : Personnalisable via les modèles de certificats (Certificate Templates) AD CS.                                                                                                                                               |
| Coûts et Complexité          |                                                                                                                                                                                                                                                                     |                                                                                                                                                                                                                                                                     |

| CRITÈRE D'ANALYSE | OPTION A : PKI PUBLIQUE INTERNE                                                                                                                                                   | OPTION B : PKI ENTREPRISE INTERNE                                                                                                                                                                                         |
|-------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                   | CERTIFY MANAGEMENT HUB / POWERSHELL / CCS                                                                                                                                         | ACTIVE DIRECTORY CS / POWERSHELL / ANSIBLE                                                                                                                                                                                |
|                   | <ul style="list-style-type: none"> <li>• Coût nul si ACME gratuit.</li> <li>• Faible infrastructure interne requise.</li> <li>• Dépendance aux APIs DNS/ACME externes.</li> </ul> | <ul style="list-style-type: none"> <li>• Exploite l'infrastructure Active Directory existante.</li> <li>• Maîtrise totale des révocations (CRL / OCSP).</li> <li>• Nécessite la gestion du cycle de vie AD CS.</li> </ul> |

### 3. Synthèse des Avantages & Inconvénients par Solution

#### Option A : PKI Publique sur les Serveurs Interne (Certify / CCS)

##### • Avantages :

- Simplicité de configuration du Reverse Proxy : aucune Autorité de Certification racine privée à importer dans le magasin de confiance TLS du RP.
- Standardisation : Même processus de gestion des certificats sur le RP et sur les serveurs applicatifs back-end.

##### • Inconvénients :

- Obligation d'exposer les nœuds internes ou de leur fournir un accès API vers le fournisseur ACME (Challenge DNS-01 nécessaire si le port 80/443 interne n'est pas joignable depuis l'extérieur).
- Renouvellement fréquent (tous les 60-90 jours) augmentant le risque de panne si un script d'automation échoue.

**Stack technique recommandée :** Certify Management Hub + Script PowerShell Post-Renew (rebond IIS/Nginx) OU Centralized Certificate Store (CCS) pour synchroniser un dossier PFX partagé entre `srv-web01` et `srv-web02`.

#### Option B : PKI Entreprise AD CS (PowerShell / Ansible)

##### • Avantages :

- **Sécurité maximale :** Fonctionne en environnement totalement hermétique (Air-Gapped / Réseau d'infrastructures restreint).
- **Souplesse :** Durée de validité personnalisable (ex: 1 ou 2 ans) réduisant l'overhead des renouvellements.
- **Intégration Active Directory :** Enrollement automatique natif (Auto-enrollment) pour les serveurs membres du domaine Windows.

##### • Inconvénients :

- Nécessite d'injecter le certificat Racine (Root CA AD CS) dans le Reverse Proxy (ex: `/etc/ssl/certs/` sous Nginx/Linux) pour qu'il fasse confiance aux serveurs web.
- Nécessite le développement et le maintien de playbooks Ansible ou de scripts PowerShell/Cron.

**Stack technique recommandée :** AD CS + Modèle de certificat Web Server + Script PowerShell d'auto-enrollement via Tâche Planifiée (Windows) OU Playbook Ansible avec module `win_certificate_store` / `get_url` (Linux/Windows).